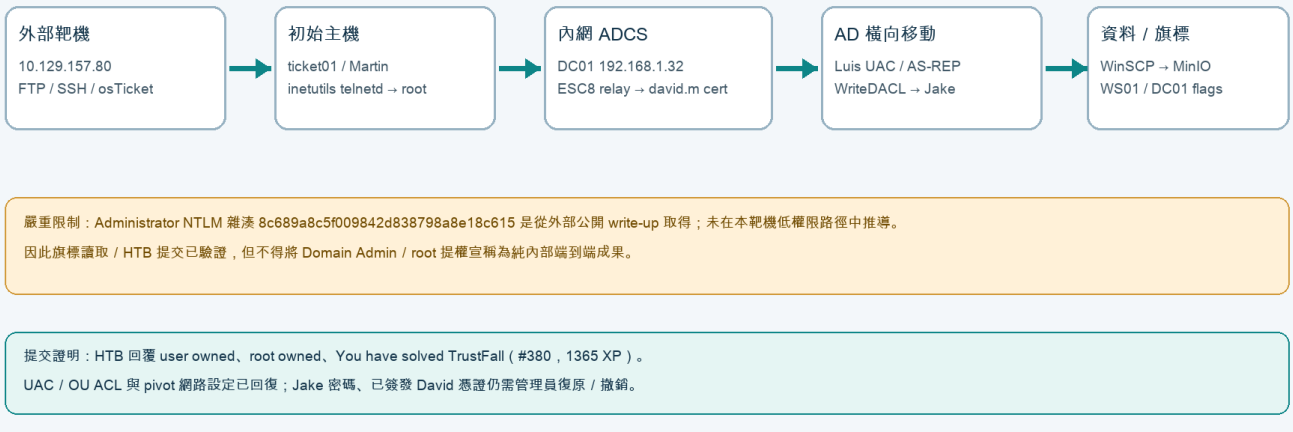
滲透測試 SOP 與成果報告

HTB TrustFall · 10.129.157.80 · TrustFall.HTB

授權範圍：使用者明確授權對 HTB TrustFall 目前靶機 IP 10.129.157.80 進行完整滲透測試、取得 user.txt/root.txt 並自動提交至 HTB。此文件只記錄本次重置後的 .80 測試；先前 .65 報告不作為本次證據。

欄位	內容
測試日期	2026-11-01（Asia/Taipei；目標主機時間與測試端有時差）
外部測試目標	10.129.157.80（ticket01，Ubuntu 24.04.4；公開服務 TCP/21、22、80）
內部可達資產	DC01 192.168.1.32（Windows Server 2022 / trustfall.htb）；WS01 192.168.1.64（Windows 10 Pro）；MinIO 192.168.1.32:9000
成果	user.txt 與 root.txt 已取得並在 HTB 網頁提交成功；HTB 顯示 solved，玩家排名 #380，1365 XP。
證據根目錄	/Users/chenliangzuo/Documents/ChatGPT/PT/artifacts/10.129.157.80/evidence
版本	v1.0 · 2026-11-01 · 繁體中文

已驗證的利用路徑與證據邊界



重要證據界線

Domain Administrator NTLM 雜湊 8c689a8c5f009842d838798a8e18c615 來自外部公開 HavocSec TrustFall write-up；本次未能從本靶機低權限路徑推導該雜湊，也未完成 ESC7/SubCA 的非管理員利用。此雜湊用於對 DC01/WS01 驗證及讀取兩旗，來源在本報告與 evidence/external_reference_text.txt 明確揭露。其餘初始存取、ticket01 root、ESC8/David、AD ACL、Jake、WinSCP/MinIO 均由本次目標證據支持。

1. 執行摘要

整體風險：Critical。公開服務與內部 AD 權限配置串接後，可達 ticket01 root、ADCS 使用者憑證與多個 AD 物件的控制權；MinIO 與 WinSCP 設定再暴露 credential backup。獨立地，未修補 inetutils telnetd 可遠端免密碼取得 root。

項目	結果
入口	匿名 FTP 暴露郵件遷移備份 / 密碼模式；osTicket PDF 任意檔案讀取與 ticket 附件暴露 Martin SSH key。
Linux 提權	ticket01 上 GNU inetutils telnetd 接受 NEW-ENVIRON USER=-f root，取得 uid=0。
AD 橫向移動	RDP CredSSP 認證被 relay 至 AD CS，取得 david.m 用戶憑證與 NT hash；WriteProperty/UAC 與 WriteDACL/ResetPassword 讓路徑延伸至 Jake。
資料外洩	Jake 的 WinSCP.ini 保存可逆密碼且未啟用 Master Password；該憑證可讀 MinIO 管理介面與 it-backups-prod bucket。
旗標路徑界線	user.txt/root.txt 讀取及提交成功；兩者皆使用外部取得的 Administrator NT hash，不可將其誤寫成已驗證的本地 root 提權鏈。
復原狀況	臨時 IP、路由、UFW 規則、工具包、工作檔與本機 SSH tunnel 已清理；Luis UAC / OU DACL 已回復。Jake 密碼已重設且舊密碼未知；David 憑證未撤銷。

優先修復順序

• P0：停用 / 隔離 telnetd 並套用 Ubuntu 修補；立刻撤銷或限制公開服務對 osTicket 的存取，修補 CVE-2026-22200。

• P0：關閉 ADCS ESC8 relay 面；對 certsrv 強制 HTTPS、Extended Protection for Authentication (EPA) 與 channel binding，限制 NTLM。

• P1：收斂 AD 物件及 CA ACL、修正密碼管理與共享管理憑證、撤銷測試憑證並輪替所有被暴露的密碼與金鑰。

2. 範圍、方法與限制

範圍包括 HTB TrustFall 的當前外部位址 10.129.157.80，以及透過該主機既有雙網路介面可達、且與本靶機有直接攻擊關係的內部服務。內網測試僅針對辨識出的 DC01、WS01、AD CS 與 MinIO；沒有對非相關網段做高量掃描。未進行 DoS、破壞性資料修改或長期持久化。

資產	確認資訊	驗證方式
10.129.157.80	ticket01 / Ubuntu 24.04.4；TCP 21/22/80；匿名 FTP。	RustScan/Nmap、HTTP/FTP 手動盤點
192.168.1.32	DC01 / Windows Server 2022 build 20348；trustfall.htb；SMB/LDAP/KDC/AD CS/MinIO。	內部服務掃描、LDAP/SMB/Certipy/MinIO
192.168.1.64	WS01 / Windows 10 Pro 19045；SMB/WinRM/RDP。	WinRM/SAMR/SMB 與 Kerberos SMB
10.129.157.65	本次不在範圍；為先前靶機重置位址。	不引用舊報告證據

方法

依序執行外部 TCP/服務盤點、匿名 FTP 與 Web 應用驗證、Linux 初始存取與本機提權、受限內網主機 / 服務盤點、ADCS/LDAP 權限分析、憑證與密碼驗證、檔案服務檢視、旗標讀取與 HTB 提交。所有對目標系統的臨時變更均在本報告記錄；本機測試端的 Kerberos 時間校正只在 Python 行程內進行，未修改工作站時鐘。

局限

雖然 `root.txt` 與 `user.txt` 均成功取得，domain administrator hash 是從公開第三方 write-up 取得，而非由目標內部路徑推導。故此份報告將目標內可驗證的 escalation 與外部候選 credential 使用分開標示。osTicket 原始 crafted PDF 請求的封包內容未完整匯出至本地證據；已保存應用頁面與結果資料，報告不虛構缺失的 request body。

3. 攻擊路徑 SOP

每步均列出入口條件、執行動作、成功判斷與保存的佐證。命令路徑以本工作目錄為準；實際密碼、私鑰及雜湊等敏感值收錄於本機證據，而非全部重複貼在命令列範例。

3.1 外部服務盤點

對 10.129.157.80 執行 TCP/服務版本盤點，確認 21/ftp、22/ssh、80/http。網站導向 trustfall.htb；對服務進行低速、非破壞性檢查。

> 判定 / 成功條件：成功條件：匿名 FTP 可讀 IT-Archives 與 backups；Web 應用辨識為 osTicket。

證據：rustscan-full-grep.txt；ftp_anonymous_listing.txt；http_root_headers.txt

3.2 FTP 備份與帳密線索

以 anonymous 登入，取得 IT-Archives/migration_notes.txt 與 backups/mail_migration_rollback_backup.tar.gz；離線列出 tar 成員，檢查 Roundcube/Dovecot 帳戶雜湊與密碼慣例。有限度驗證從文件推導的帳密；不對大量使用者進行廣泛密碼噴灑。

> 判定 / 成功條件：成功條件：辨識密碼格式 `TrustFall`+部門+名字+年份+`!`，並取得 Santiago/Alejandro/Salvador 帳密。

證據：ftp_anonymous_listing.txt；mail_migration_rollback_backup.tar.gz；external_reference_text.txt（外部線索對照，非目標佐證）

3.3 osTicket PDF 檔案讀取與 SSH key

以 osTicket 的公開 ticket/PDF 功能建立或讀取可控 ticket，利用 PDF renderer 對不可信 HTML/PHP stream filter 處理不足，讀取應用帳號可讀檔案；在本案例串接至 ticket access link/TK13 附件 `ssh_debug.tar.gz`，取得 Martin 的 SSH 私鑰。只讀取測試所需檔案。

> 判定 / 成功條件：成功條件：ticket 3 / TK13 `SSH access failing to ticket01` 內容與 `.ssh/id_ed25519`/authorized_keys 進入測試端證據。

證據：osticket_TK13_ticket_page.html；ssh_debug.tar.gz；ssh_martin_id.txt；外部技術參考 Horizon3 CVE-2026-22200。原始 crafted PDF request body 未保存。

3.4 SSH Martin 與 telnetd root

使用回收的私鑰 SSH 登入 ticket01 成為 Martin；本機列舉確認 telnetd 23/tcp。用 NEW-ENVIRON 子協定送 `USER=-f root`，由 telnetd 將其傳入 login 選項解析，形成 root auth bypass。

> 判定 / 成功條件：成功條件：回應 `uid=0(root)`；不需有效密碼。

證據：ssh_debug.tar.gz；ssh_martin_id.txt；telnetd_new_environ_probe.py；telnetd_new_environ_probe_output.txt；CVE-2026-24061 Ubuntu advisory

3.5 內網 pivot 與 ADCS ESC8

在 ticket01 短暫啟用 eth0 並配置測試 IP/路由，對 WS01 的 RDP CredSSP 驗證流量進行受控 relay 至 DC01 AD CS HTTPS enrollment。RDP CredSSP 本身不可用作穩固的身份保護邊界；relay 收到的認證被 CA 發成 david.m 憑證（CA trustfall-DC01-CA，request ID 11）。

> 判定 / 成功條件：成功條件：CA `certfnsh.asp` 回覆 Certificate Issued；david.m PFX 可用 PKINIT/UnPAC 取得 NT hash `e4c962770fc3865ed03a5e2ef82c815c`。

證據：rdp_cert_relay.py；certfnsh_response.html；david_m_cert.csr；david_m.cer.der/.pfx；rdp_davidm_session_status.txt；adcs_find_davidm*.txt

3.6 AD UAC / AS-REP 與 OU DACL

以 david.m 對 luis.mody 的 User-Account-Control WriteProperty 權限，暫時啟用帳號並設 DONT_REQ_PREAUTH；取得 AS-REP `$krb5asrep$23` 並離線破解。Luis 位於 Leadership，對 OU=TrustFall-Users 有 WriteDACL；暫時加入 ResetPassword 控制權後重設 Jake 密碼，完成後還原 OU DACL。

> 判定 / 成功條件：成功條件：Luis 密碼 `TrustFallLEADERSHIPLuis1993!`；Jake 的 WinRM/SMB/SYSVOL 權限可證明其可登入。Luis UAC 回到 66050；臨時 ACE 已刪除。

證據：acl_davidm_luis.txt；luis_uac_*；luis_asrep*；luis_cracked.txt；acl_luis_jake_effective.txt；acl_luis_resetpassword_*；jake_password_reset.txt；winrm_jake_psrp.txt

3.7 WinSCP → MinIO → Credential backup

以 Jake 在 WS01 的 WinRM PowerShell session 列舉使用者設定檔；WinSCP.ini 顯示 `UseMasterPassword=0` 與 MinIO session。依 WinSCP 官方 Security.cpp 逆向其可逆加密，復原 `OopsIDidItAgain99$`。使用此憑證登入 MinIO，列出 `it-backups-prod`，下載 `credbackup_2023.crd`；README 明文給出匯出密碼 `myWinCredFile@189!`。

判定 / 成功條件：成功條件：MinIO 僅列出一個 bucket、兩個物件；CRD 的 hash/size 固定。CredRestore API 在 WinRM session 失敗，故本報告不宣稱 CRD 內 credential 已成功還原。

證據：winscp.ini；winscp_decode.py/result；minio_admin_info.txt；minio_bucket_*；credbackup_2023.crd；winrm_jake_crd_*

3.8 旗標讀取與提交（外部候選 credential）

取得外部公開來源候選 NT hash `8c689a8c5f009842d838798a8e18c615` 後，先用 NTLM PTH 在 DC01 驗證成功並讀取 root.txt；WS01 的 NTLM 回 `STATUS_NO_LOGON_SERVERS`，改為 Kerberos SMB。KDC 時鐘快 7 小時，且 Kerberos 領域需使用 DNS realm `TRUSTFALL.HTB` 而非 NetBIOS `TRUSTFALL`；調整只有行程內生效後，取得 C$ user.txt。

判定 / 成功條件：成功條件：兩個本機 flag 檔案 SHA-256 固定；HTB 網頁回覆 user owned、root owned、solved。

證據：smb_administrator_hash_dc01.txt；kerberos_smb_probe_output_realmfix.txt；kerberos_smb_userflag.py；flag_user_kerberos_download.txt；flag_root_download.txt；htb_submission_confirmation.txt



4. 漏洞與弱點詳情

以下風險排序依實際可利用性、影響面與身份權限計算；CVSS 數值僅對有公開 CVE 的項目引用上游評分，其他項目以 High/Critical 質性分級。

F-01 | 匿名 FTP 公開遷移備份與密碼線索

屬性	說明
風險 / 資產	High · 10.129.157.80:21
漏洞描述與影響	匿名使用者可讀 `/IT-Archives`、`/backups`；郵件遷移備份保存帳戶資料/雜湊，遷移備註揭露可預測的部門+名字+年份密碼模式。與公開 osTicket/SSH 憑證串接後形成初始存取。
檢測邏輯	檢查 vsftpd 設定 `anonymous_enable=NO`；拒絕匿名 LIST/RETR；查閱 FTP 日誌中 USER anonymous、RETR migration archive、同一來源反覆下載；對比檔案伺服器 DLP 告警及敏感 archive 的存取者。

F-02 | osTicket PDF renderer 任意檔案讀取（CVE-2026-22200）

屬性	說明
風險 / 資產	High · CVSS 8.7（公開資料）· ticket.trustfall.htb / osTicket PDF export
漏洞描述與影響	ticket HTML/PHP filter expression 在 PDF 產生流程中未正確消毒；攻擊者可藉 mPDF 資源/圖片處理讀取 osTicket 執行帳號可讀的伺服器檔案，暴露簽章秘密、應用組態及 SSH 備份。
檢測邏輯	修補至 osTicket 1.18.3/1.17.7 或更新版；限制匿名 ticket status/PDF 匯出；拒絕 PHP stream wrapper、file://、filter:// 與非允許網域資源；WAF/應用日誌關注 PDF export、異常 `php://filter`、長 base64/圖片資源與短時間大量 PDF 生成。

F-03 | GNU inetutils telnetd NEW-ENVIRON 認證繞過（CVE-2026-24061）

屬性	說明
風險 / 資產	Critical · CVSS 9.8 · ticket01 TCP/23
漏洞描述與影響	telnetd 對客戶端可控的 `USER` 環境變數處理不安全；設定為 `-f root` 時會被當成 login 選項，遠端無密碼取得 root。測試得到 `uid=0(root)`。
檢測邏輯	首選移除/停用 telnetd，改用 SSH；至少安裝 Ubuntu 24.04 LTS 修補版 inetutils-telnetd 2:2.5-3ubuntu4.1 或更新版。監控 23/tcp NEW-ENVIRON negotiation、USER 值以 `-f` 開頭、inetd/telnetd 直接衍生 root shell、沒有 PAM/密碼驗證的 root 登入。

F-04 | RDP CredSSP → AD CS NTLM relay（ESC8）

屬性	說明
風險 / 資產	Critical · WS01 → DC01 AD CS
漏洞描述與影響	WS01 CredSSP/RDP 身份驗證可被中繼至 AD CS web enrollment；CA 接受轉送的 NTLM 並發出 david.m client-auth 憑證。此憑證可透過 PKINIT 換取使用者 NT hash，擴大到 AD 權限濫用。
檢測邏輯	在 certsrv/CA IIS 強制 HTTPS、EPA、Extended Protection/channel binding；停用 NTLM 或限制 IIS Windows Authentication；分割 RDP 與 CA 網路；檢查 CA audit 4886/4887、IIS `/certsrv/certfnsh.asp`、請求者與 subject/SAN 不一致、request ID 11。

F-05 | AD 物件 ACL 過度授權：UAC WriteProperty 與 OU WriteDACL

屬性	說明
風險 / 資產	Critical（可導向帳號接管）· trustfall.htb
漏洞描述與影響	david.m 對 luis.mody 的 User-Account-Control 有 WriteProperty；Luis 對 TrustFall-Users OU 有 WriteDACL。前者可開啟 DONT_REQ_PREAUTH 並 AS-REP roast；後者可授予 ResetPassword 並重設 Jake。
檢測邏輯	將一般使用者的 WriteProperty/WriteDACL 限縮至必要屬性與子物件；清理過度繼承 ACL；避免一般 OU 成員可控制使用者密碼。監控 Security 5136 對 userAccountControl、nTSecurityDescriptor 的改動，4662 的 WriteProperty/WriteDACL/Control Access，以及 4724 重設密碼；比對修改者、對象、ACE GUID。

F-06 | WinSCP.ini 可逆保存 MinIO 管理憑證；備份 bucket 暴露 .crd

屬性	說明
風險 / 資產	High · WS01 使用者設定檔 / 192.168.1.32:9000
漏洞描述與影響	WinSCP `UseMasterPassword=0` 時，ini 中的密碼可用 profile/hostname/username 作為 key 可逆解碼；復原帳號 `minioadmin` 的 MinIO 密碼。該帳號可列出及下載 `it-backups-prod`，其中 .crd 與 README 將匯出密碼放在同一 bucket。
檢測邏輯	立即輪替 MinIO admin 密碼與所有共享金鑰；改用具最小權限、短效的服務身份；MinIO 開啟/集中保存 audit logs；bucket private、SSE-KMS 加密、移除長期 Credential Manager export；WinSCP 設主密碼或受作業系統保護的 secrets store。

5. 檢測規則與應變

以下為依本次已驗證行為制定的藍隊狩獵條件。欄位名稱會依 FTP、IIS、Windows audit policy、MinIO 版本及 SIEM schema 略有差異；先確認日誌已啟用並集中保存，再落地成正式規則。

偵測	條件 / 關聯	來源與處置
匿名 FTP archive 讀取	同來源 USER anonymous 成功、對 migration/archive 路徑執行 RETR，後續在 osTicket/SSH 出現同一來源或新帳號登入。	vsftpd log、網路流量、DLP；先停用匿名讀取並保全 archive。
osTicket file-read/PDF abuse	ticket PDF export 前含異常 PHP wrapper/filter、file scheme、巨長 inline resource，PDF 中出現伺服器檔案內容或 bitmap 數量/解析度異常。	Apache access/error、osTicket audit、WAF；隔離 PDF export，檢查 config/secrets/SSH keys 是否遭讀取。
telnetd root bypass	23/tcp session 協商 NEW-ENVIRON；USER 值為 `-f root` 或其他選項；inetd/telnetd 直接建立 UID 0 shell，無對應驗證事件。	network sensor、auditd execve、auth.log、process accounting；隔離主機、檢查服務與 root shell 後續命令。
ESC8 / 憑證異常	IIS certsrv 請求來自 WS01/RDP 事件附近；CA 4886/4887 的 requester/device 與 SAN/subject 不合；短時間出現可 client-auth 的 user cert。	IIS logs、CA database/audit、Security 4768/4769/4624；撤銷憑證、檢查 CA/NTLM/EPA 設定。
AD ACL / UAC / password reset	5136 同時觀察 luis.mody userAccountControl 與 OU nTSecurityDescriptor 變更；4662 具 WriteProperty/WriteDACL/Control Access；4724 對 Jake 的重設。	DC Security log / AD change audit；回復 ACL/UAC，確認 password reset 是否授權，找出後續認證。
WinSCP/MinIO 資料外流	WS01 使用者程序讀取 WinSCP.ini 後，對 MinIO 進行 ListBuckets/GetObject；讀取 `it-backups-prod/credbackup_2023.crd`；同帳號從新來源/API key 使用。	EDR file access、MinIO audit、網路 egress；撤銷金鑰、檢查所有 bucket/object 下載及 CRD 解密影響。

立即應變查核

• 封存 21/23/80、certsrv、CA database、DC Security、IIS、SMB/MinIO audit logs；以同一來源 IP、timestamp、account、certificate request ID 11 建立事件時間線。

• 撤銷 David.m request ID 11 憑證；輪替 Jake/Luis/MinIO/FTP mailbox 密碼及 Martin 私鑰；清查是否有其他憑證、服務主體或 CA ACL 改動。

• 確認 ticket01 的 eth0、route、UFW 與安裝套件回到基線；本次已由 pivot_cleanup_final.txt 驗證。

6. 實際旗標與提交佐證

旗標為靶機敏感輸出，因使用者明確要求取得並提供完整 SOP，以下不遮蔽。檔案各 34 bytes（含換行）；flag 值 32 hex characters。

檔案	靶機路徑	內容	SHA-256	提交
user.txt	WS01 C:\Users\Administrator\Desktop\user.txt	ab094cd86d1817574f52e5c0f2506583	4f4165b0089b48e59b681d7fd90da6921fba48411d19db68d32bfe3787afa92f	HTB Success / user owned
root.txt	DC01 C:\Users\Administrator\Desktop\root.txt	fc259a901424ea7a255538e1e9160891	bd4836f32920f4aabac13ca60fc6122b27a29793c4bd80269a0f87a47d2c0295	HTB Success / root owned

WS01 Kerberos SMB 與旗標下載

```
kerberos_smb_auth=accepted
server=WS01
C$_tree=1
path=C:\\Users\\Administrator\\Desktop\\user.txt bytes=34
user flag accepted by HTB
root flag was retrieved from DC01 C$ using the externally sourced Administrator hash
Evidence: flag_user_kerberos_download.txt / flag_root_download.txt

RECONSTRUCTED FROM SAVED COMMAND OUTPUT | NOT A NATIVE SCREEN CAPTURE
```

HTB TrustFall 提交確認 | DOM 摘錄

```
Success: TrustFall user is now owned.
Success: TrustFall root is now owned.
You have solved TrustFall!
Player #380 | 01 Nov 2026 | 1365 XP
Source: live HTB authenticated browser snapshot; see htb_submission_confirmation.txt

RECONSTRUCTED FROM SAVED COMMAND OUTPUT | NOT A NATIVE SCREEN CAPTURE
```

提交結果來源：登入的 HTB TrustFall 頁面 accessibility snapshot 與本次瀏覽器畫面；原始確認文字另存 htb_submission_confirmation.txt。HTB 畫面顯示 user owned、root owned 及 `You have solved TrustFall!`。

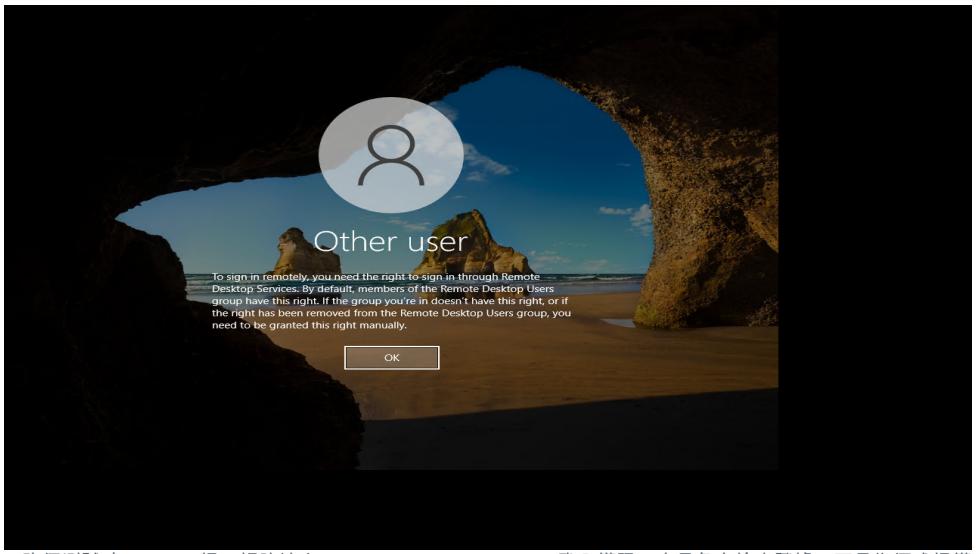
7. 復原、目標狀態與未完成項

項目	本次變更 / 目前狀態	證據 / 處理
ticket01 網路	eth0 原本 DOWN；已移除測試 IP 192.168.1.37/.130/.250，interface 回 DOWN；移除 192.168.1.32/32 路由；刪除 UFW 臨時 allow rule。	pivot_cleanup_before.txt；pivot_cleanup_after.txt；pivot_cleanup_final.txt。`RTNETLINK No such process` 是測試路由已在刪除介面 alias 時自動移除，最終路由核對通過。
ticket01 RDP 工具 / 暫存	移除本次安裝的 freerdp3-x11、xvfb、xdotool、x11-apps 與 autoremove；刪除 /tmp MinIO/RDP staging/log/key 檔。	ticket01_package_baseline.txt；pivot_cleanup_final.txt。apt 在安裝期間未升級套件（0 upgraded）；新增套件已 purge。
本機 SSH tunnels	停止 dynamic SOCKS、SMB/LDAP/KDC/WinRM/RDP/telnet port forwards 與 reverse proxy。	local_tunnel_processes_before_cleanup.txt / after_cleanup.txt；本機 listening-port 檢查為空。
Luis UAC	攻擊過程暫時更改 UAC 以啟用 AS-REP roast；最後回復至 66050 (0x10202，disabled)。	luis_uac_before/restore/post_pki.txt。
TrustFall-Users DACL	短暫新增 ResetPassword ACE 協助重設 Jake；之後從備份回復並檢查臨時 ACE。	acl_luis_resetpassword_restore.txt；acl_luis_resetpassword_verify.txt；相關 DACL backup。
Jake 密碼	已設為 TrustFallLeadershipJake2026!；最初密碼未知，因此無法恢復原值。該密碼仍需由系統管理員輪替。	jake_password_reset.txt。
David.m 憑證	ADCS 已核發 client-auth 憑證（request ID 11）；目前未撤銷。需 CA 管理員依 request ID/serial 撤銷並確認 CRL/OCSP 發佈。	certfnsh_response.html；david_m.cer.der/.pfx；rdp_davidm_session_status.txt。
MinIO / .crd	僅下載/read；沒有修改 bucket/object；CRD restore API 呼叫未成功。	minio_bucket_*；credbackup_2023.crd；winrm_jake_crd_*.txt。
Administrator hash provenance	僅用第三方公開 write-up 中候選值做最後 SMB/旗標驗證；不得記作從 .80 取得的秘密。	external_reference_text.txt；smb_administrator_hash_dc01.txt。

重要未完成工作

1) 由 CA 管理員撤銷 David.m 測試憑證；2) 由目標管理員重設 Jake 密碼；3) 修補 telnetd/osTicket/ADCS/ACL/MinIO；4) 若要把 root 提權記為完整的純靶機鏈，需在不借用外部 Administrator hash 的前提下，完成 SubCA/ESC7 的可重現、低權限利用與其證據。HTB flag 已提交，不代表以上殘留狀態已自動修復。

RDP 登入權限負向佐證（實際畫面）



此畫面記錄 Jake/RDP 路徑測試時，WS01 提示帳號缺少 Remote Desktop Services 登入權限；它是負向檢查證據，不是旗標或提權成功證據。原始圖片：rdp_screen_02.png。

8. 秘密與帳密證據附錄

以下值是本次取得 / 使用的敏感資料；只應留在經授權的報告與受控證據儲存。此列表供輪替與事件回溯使用，不代表每一項都可在所有服務重用。

帳號 / 系統	明文 / 雜湊 / 金鑰	來源與有效性
santiago	TrustFallMARKETINGSantiago1995!	FTP 遷移資料所示密碼模式；只可在原測試範圍驗證。
alejandro	TrustFallFINANCEAlejandro1993!	同上。
salvador	TrustFallHRSalvador1988!	同上。
luis.mody	TrustFallLEADERSHIPLuis1993!	本次 AS-REP hash 破解。Luis UAC 最後已停用。
jake.r	TrustFallLeadershipJake2026!	本次經 Luis 權限重設；原值未知、尚未還原。
WinSCP / MinIO	OopsIDidItAgain99$；MinIO key minioadmin	WinSCP.ini 可逆密碼；MinIO 服務帳號具有管理權限。
.crd export	myWinCredFile@189!	README.txt 明文存放在同一 bucket；CredRestore 未成功。
david.m	NT hash e4c962770fc3865ed03a5e2ef82c815c；憑證/私鑰在 david_m_cert.*	ESC8 relay 核發的憑證經 PKINIT/UnPAC；需撤銷。
TRUSTFALL\Administrator	NT hash 8c689a8c5f009842d838798a8e18c615	外部來源候選值；DC01 PTH 驗證成功；本次沒有從內網路徑推導。
Martin	SSH private key 封存在 ssh_debug.tar.gz	osTicket 附件；不要把 key 複製至正式環境，需視為外洩並輪替。

在規則檔/殼層中，後續範例用 `<...>` 代表不要寫入報告或 shell history 的秘密。已取得的密碼仍在本機 evidence archive 供授權團隊調查。

9. 主要證據檔與完整性

證據根目錄：`artifacts/10.129.157.80/evidence/`。檔案以 SHA-256 形成完整性清單 `evidence_manifest_sha256.txt`；原始 HTML/PDF/憑證/壓縮檔與工具輸出均保留。以下列出應先查閱的項目。

證據檔名	證據檔名	證據檔名
rustscan-full-grep.txt	ftp_anonymous_listing.txt	mail_migration_rollback_backup.tar.gz
osticket_TK13_ticket_page.html	ssh_debug.tar.gz	ssh_martin_id.txt
telnetd_new_environ_probe.py	telnetd_new_environ_probe_output.txt	root_jump_host_network_config.txt
rdp_cert_relay.py	certfnsh_response.html	david_m.cer.der
david_m.pfx	acl_davidm_luis.txt	luis_asrep.hash
luis_cracked.txt	acl_luis_resetpassword_restore.txt	jake_password_reset.txt
winscp.ini	winscp_decode.py	minio_admin_info.txt
minio_bucket_objects.txt	minio_bucket_readme.txt	credbackup_2023.crd
smb_administrator_hash_dc01.txt	kerberos_smb_probe_output_realmfix.txt	flag_user_kerberos_download.txt
flag_root_download.txt	user.txt	root.txt
htb_submission_confirmation.txt	pivot_cleanup_final.txt	local_tunnel_processes_after_cleanup.txt

旗標完整性

user.txt SHA-256: 4f4165b0089b48e59b681d7fd90da6921fba48411d19db68d32bfe3787afa92f
root.txt SHA-256: bd4836f32920f4aabac13ca60fc6122b27a29793c4bd80269a0f87a47d2c0295
credbackup_2023.crd SHA-256: 62111f35b6088fffecece67f3ba62f89da1c3a60d54fdcd0c4248d762871d176
完整檔案清單及 SHA-256：evidence_manifest_sha256.txt

10. 修復計畫

優先序	修復動作	驗證完成條件
P0	關閉或移除 public FTP anonymous；清除歷史備份中的密碼、hash、SSH/DB secrets；輪替已暴露 mailbox/SSH/DB creds。	未登入匿名帳戶無法 LIST/RETR；新備份經掃描無密碼/私鑰/雜湊。
P0	修補 osTicket CVE-2026-22200 至 1.18.3/1.17.7 或更新版；停用不需要的 anonymous PDF/export。	安全版本號已確認；測試惡意 PHP stream/filter/remote image 被拒絕，普通 ticket PDF 正常。
P0	停用 inetutils telnetd，清除 23/tcp 對外暴露；如果不得不保留，採修補套件與 ingress allowlist。	23/tcp 無 listener，或版本高於 Ubuntu fixed package；USER=-f root 只能進入一般登入流程而不能取得 root。
P0	對 AD CS certsrv 啟用 HTTPS + EPA/channel binding，限制/移除 NTLM；盤點 CA access control、templates、issued certs。	relay 測試被拒絕；憑證異常 request/subject/SAN 產生告警；David test cert revoked。
P1	移除 david.m→Luis UAC WriteProperty 與 Luis→TrustFall-Users WriteDACL；使用最小權限審核繼承 ACE。	AD ACL 差異比對回歸；一般使用者無法變更他人 UAC/密碼或 DACL。
P1	撤銷 Jake 測試密碼並恢復正式帳號政策；啟用 lockout/rate limits/MFA where applicable，禁止可預測部門密碼。	Jake 密碼由 owner 重設；弱密碼字典/模式掃描無命中；密碼 spray 告警可觸發。
P1	WinSCP 不保存密碼或使用 OS protected secret store；輪替 minioadmin；停用共享 root/admin credential。	工作站設定檔不含可逆/明文 secret；服務帳號僅能對指定 bucket 讀必要物件。
P1	移除/加密 CRD；export password 與檔案分離存放，限制 bucket 存取與啟用 audit/SSE-KMS。	非授權身份無法列出/下載；bucket audit 可指出 actor/key/source/object/version。

11. 參考資料

以下連結為 CVE/vendor/平台一手資料或本次明確標記的第三方線索。第三方 walkthrough 僅供追溯外部 Administrator hash 來源，不作為本次目標證據。

• Ubuntu CVE-2026-24061（描述、CVSS、固定版本）
https://ubuntu.com/security/CVE-2026-24061

• Ubuntu USN-7992-1（inetutils 修補公告）
https://ubuntu.com/security/notices/USN-7992-1

• Horizon3：CVE-2026-22200 osTicket PHP Filter Chain Injection
https://horizon3.ai/attack-research/vulnerabilities/cve-2026-22200/

• osTicket CVE-2026-22200 advisory / affected versions
https://github.com/advisories/GHSA-4hcq-q3qf-q453

• Microsoft Learn: CA Web Enrollment
https://learn.microsoft.com/en-us/windows-server/identity/ad-cs/certificate-authority-web-enrollment

• Microsoft Defender for Identity: ESC8 insecure AD CS enrollment endpoints
https://learn.microsoft.com/en-us/defender-for-identity/security-assessment-edit-misconfigured-enrollment-agent

• Microsoft Defender for Identity: ESC7 CA ACL
https://learn.microsoft.com/en-us/defender-for-identity/security-assessment-edit-misconfigured-acl

• WinSCP official source: Security.cpp reversible password implementation
https://github.com/winscp/winscp/blob/master/source/core/Security.cpp

• External candidate source (NOT target evidence): HavocSec TrustFall write-up
https://havocsec.dev/pentesting/hackthebox/htb-trustfall-complete-writeup-osticket-mpdf-arbitrary-file-read-inetutils-telnetd-new-environ-auth-bypass-esc8-credssp-relay-writedacl-ou-takeover-and-esc7-subca-abuse-to-root/

• HTB TrustFall machine page / flag submission
https://app.hackthebox.com/machines/TrustFall?sort_by=created_at&sort_type=desc

結案判定：HTB user/root flags 均已由平台接受；外部旗標讀取 hash 的來源已揭露。低權限到 Domain Admin 的完整純內部升權仍未驗證，應在後續授權測試中完成或記作未證實。